

Cyber Threat Intelligence

Executive Briefing

Report Date: July 01, 2026

Generated: 2026-07-01 13:55 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
4	4	12	0	20

2. Executive Summary

As of July 01, 2026, the security operations center has concluded an analysis of 20 identified vulnerabilities, categorized as 4 Critical, 4 High, 12 Medium, and 0 Low severity findings. The current organizational risk posture is assessed as 'High' according to CVSS v3.1 scoring, reflecting a significant potential for unauthorized access to core environment runtimes. The primary threat is CVE-2026-50566, the Fission Container SecurityContext Bypass, which constitutes our most urgent priority due to its capacity to circumvent hardened container isolation controls. We recommend an immediate transition to an expedited remediation posture, requiring the isolation of affected container environments until patches are verified and deployed.

3. Critical Action List

1. Immediately revoke and rotate all container environment credentials and apply the vendor-supplied patch for CVE-2026-50566 within 24 hours.
2. Restrict access to Fulcio OIDC discovery endpoints and implement strict egress filtering to mitigate CVE-2026-49478 within 48 hours.
3. Suspend all external access to Oban Web event handlers and apply the necessary authorization logic updates for CVE-2026-48592 within 48 hours.
4. Audit all AdonisJS data intake processes and implement the provided prototype pollution patches for CVE-2026-48795 within 72 hours.
5. Restrict input processing to the Open Babel SMILES parser and initiate patching cycles for CVE-2025-10996 within 96 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
--------	--------------	------	----------	---------	-----

CVE-2026-50566	Fission Container SecurityContext...	9.9	Critical	99/100	CWE-250
CVE-2026-49478	SSRF and Token Leakage in Fulcio	9.8	Critical	78/100	CWE-918
CVE-2026-48592	Missing Authorization in Oban Web	9.1	Critical	78/100	CWE-862
CVE-2026-48795	Incomplete Prototype Pollution Fi...	9.8	Critical	77/100	CWE-1321
CVE-2025-10996	Heap Overflow in Open Babel SMILE...	7.8	High	65/100	CWE-119
CVE-2025-10995	Out-of-Bounds Write in ZipStream ...	7.8	High	65/100	CWE-787
CVE-2025-10994	Use-after-free in GAMESS Molecule...	7.8	High	65/100	CWE-119
CVE-2026-48593	Unbounded Range Expansion in Oban...	7.5	High	63/100	CWE-400
CVE-2026-3408	NULL Pointer Dereference in CDXML...	6.5	Medium	60/100	CWE-476
CVE-2026-2705	NULL Pointer Dereference in MOL2 ...	6.5	Medium	60/100	CWE-119
CVE-2026-48808	Twig Sandbox Property Allowlist B...	6.5	Medium	54/100	CWE-693
CVE-2026-48807	Twig Sandbox __toString Policy By...	6.5	Medium	54/100	CWE-693
CVE-2026-48806	Twig Sandbox Mapping Keys Bypass	6.5	Medium	54/100	CWE-693
CVE-2026-50565	ServiceAccount Token Exposure in ...	5.9	Medium	54/100	CWE-250
CVE-2026-49835	OOM in Sigstore Timestamp Authori...	5.9	Medium	53/100	CWE-770
CVE-2026-2704	Out-of-Bounds Read in CIF Transfo...	5.4	Medium	50/100	CWE-119
CVE-2026-48796	Path Traversal in CefSharp Folder...	5.3	Medium	48/100	CWE-22
CVE-2026-55219	Credit Double-Spend Race Conditio...	5.3	Medium	43/100	CWE-362
CVE-2026-49820	Open Redirect via Path Normalizat...	6.1	Medium	37/100	CWE-601
CVE-2026-48805	Twig Sandbox State Regression	5.3	Medium	30/100	CWE-693

5. Detailed Vulnerability Findings

CVE-2026-50566

Finding: Fission Container SecurityContext Bypass

CVSS v3.1 Score: 9.9 | Severity: Critical | Urgency Score: 99/100 | CWE: CWE-250

MITRE ATT&CK: T1611, T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

Fission's Environment Runtime and Builder container SecurityContext configurations contain a bypass that allows the creation of privileged pods. This vulnerability stems from improper validation of container security specifications in the Fission resource controllers. An attacker can exploit this to escape the container boundary and gain elevated node-level access.

Proof of Concept (PoC):

An authenticated user with low-level privileges creates a new Fission Environment with a manipulated SecurityContext section. The Fission controller fails to validate the nested properties of the pod specification against security constraints. The system deploys a container running in privileged mode, providing the attacker full root access to the host node. This results in total compromise of the Kubernetes cluster environment.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50566>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50566>

CVE-2026-49478

Finding: SSRF and Token Leakage in Fulcio

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 78/100 | CWE: CWE-918

MITRE ATT&CK: T1190, T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	High	Availability Impact	High

Description:

Fulcio has an OIDC discovery redirect following vulnerability that allows SSRF and JWKS substitution for meta-issuer paths, resulting in Kubernetes service-account token leakage. The root cause is the application's failure to validate and restrict the target of redirect responses during OIDC discovery. An attacker can exploit this to forge tokens or gain unauthorized access to internal infrastructure.

Proof of Concept (PoC):

An unauthenticated attacker sends a request to Fulcio with a forged OIDC issuer URL pointing to a malicious server. Fulcio follows the redirect and consumes the malicious JWKS configuration, allowing the attacker to sign arbitrary tokens. The attacker then provides a token that impersonates a valid service identity, leading to the exfiltration of the Kubernetes service-account token. This grants the attacker full control over the related service-account permissions.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49478>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49478>

CVE-2026-48592

Finding: Missing Authorization in Oban Web

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 78/100 | CWE: CWE-862

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	High	Availability Impact	High

Description:

Oban Web is vulnerable due to a missing authorization check on the 'save-job' event handler. An attacker can interact with this handler to create, delete, or modify jobs regardless of their actual permissions. This leads to an insecure direct object reference condition that can be abused to manipulate system background tasks.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a POST request to the internal '/save-job' endpoint of Oban Web. The application processes the request directly without confirming that the requester has administrative session credentials. The attacker modifies critical job parameters or creates new tasks that the system will automatically execute. This allows for total control over asynchronous task processing.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48592>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48592>

CVE-2026-48795

Finding: Incomplete Prototype Pollution Fix in AdonisJS

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 77/100 | CWE: CWE-1321

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

@adonisjs/bodyparser has an incomplete fix for CVE-2026-25754, leaving the application vulnerable to prototype pollution via specifically crafted input payloads. The flaw allows an attacker to manipulate the object prototype, potentially overriding configuration or injecting dangerous properties into the application environment. This can lead to remote code execution or complete service takeover.

Proof of Concept (PoC):

An attacker sends a POST request with a JSON payload containing recursive '__proto__' or 'constructor' properties. The bodyparser incorrectly merges these properties into the global object prototype because the previous fix did not account for all merging scenarios. Once the prototype is polluted, the attacker triggers an application function that relies on polluted keys to execute commands. This results in arbitrary code execution on the server.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48795>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48795>

CVE-2025-10996

Finding: Heap Overflow in Open Babel SMILES Parser

CVSS v3.1 Score: 7.8 | Severity: High | Urgency Score: 65/100 | CWE: CWE-119

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Local
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

Open Babel has a heap buffer overflow in the SMILES OBSmilesParser::ParseSmiles method. The vulnerability occurs due to a lack of proper boundary checks when parsing malformed chemical structure files. This allows an attacker to corrupt memory, potentially leading to arbitrary code execution or a crash of the service.

Proof of Concept (PoC):

A user opens a maliciously crafted SMILES chemical file using the Open Babel utility. The ParseSmiles function fails to validate the length of the string buffer during processing. This trigger leads to a heap-based buffer overflow condition. The resulting memory corruption enables local attackers to disrupt application stability.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2025-10996>

Ref: <https://www.cve.org/CVERecord?id=CVE-2025-10996>

CVE-2025-10995**Finding: Out-of-Bounds Write in ZipStream Unzip**

CVSS v3.1 Score: 7.8 | Severity: High | Urgency Score: 65/100 | CWE: CWE-787

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Local
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

Open Babel has an out-of-bounds write vulnerability in the zipstream basic_unzip_streambuf::underflow method. This failure is caused by an overlapping memcpy operation performed without appropriate buffer verification. A successful exploit can lead to memory corruption, potentially compromising the integrity of the application process.

Proof of Concept (PoC):

A local attacker provides a malformed compressed archive file that triggers the underflow method in zipstream. The basic_unzip_streambuf implementation performs an overlapping memory copy during the decompression process. This action overwrites adjacent memory segments with attacker-controlled data. Ultimately, this results in controlled memory corruption during file parsing.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2025-10995>

Ref: <https://www.cve.org/CVERecord?id=CVE-2025-10995>

CVE-2025-10994**Finding: Use-after-free in GAMESS Molecule Parsing**

CVSS v3.1 Score: 7.8 | Severity: High | Urgency Score: 65/100 | CWE: CWE-119

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Local
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

Open Babel exhibits a use-after-free vulnerability within the GAMESS GAMESSOutputFormat::ReadMolecule function. The issue arises due to improper memory deallocation and subsequent access to pointers that have already been freed. An attacker can exploit this state to cause application crashes or perform remote code execution.

Proof of Concept (PoC):

A local attacker provides a crafted GAMESS output file containing malformed molecule data to the Open Babel tool. The ReadMolecule parser frees the memory object before the final processing step, but still attempts to reference the memory address. This leads to a use-after-free condition when the logic attempts to re-access the invalid pointer. The final impact is an illegal application state that could lead to privilege escalation.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2025-10994>

Ref: <https://www.cve.org/CVERecord?id=CVE-2025-10994>

CVE-2026-48593**Finding: Unbounded Range Expansion in Oban Cron**

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 63/100 | CWE: CWE-400

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Oban Web suffers from an unbounded range expansion vulnerability within the cron describe function that causes memory exhaustion. The failure is due to a lack of limits on the number of cron occurrences generated when expanding complex cron strings. This allows an attacker to cause a denial-of-service by submitting malicious cron schedules.

Proof of Concept (PoC):

An attacker provides an extremely wide range definition in the cron schedule input field of Oban Web. The application logic attempts to generate and store all possible schedule occurrences in memory without checking bounds. The resulting memory allocation exceeds the process heap, leading to a crash. The system becomes unavailable for other legitimate background processes.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48593>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48593>

CVE-2026-3408

Finding: NULL Pointer Dereference in CDXML Parser

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 60/100 | CWE: CWE-476

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	None
Availability Impact	High

Description:

Open Babel has a NULL pointer dereference in the CDXML OBAtom::GetExplicitValence method. This defect is caused by a failure to validate object pointers before accessing member variables during chemical structure parsing. Remote exploitation results in a denial of service by terminating the application thread.

Proof of Concept (PoC):

An attacker uploads a specially crafted CDXML file to a service using Open Babel. The processing logic attempts to invoke OBAtom::GetExplicitValence on an uninitialized or NULL atom object. The application fails to check for nullity and dereferences the pointer, causing an immediate crash. This effectively creates a persistent denial-of-service condition for the specific processing pipeline.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-3408>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-3408>

CVE-2026-2705

Finding: NULL Pointer Dereference in MOL2 Parser

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 60/100 | CWE: CWE-119

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	None
Availability Impact	High

Description:

Open Babel exhibits a NULL pointer dereference in the MOL2 OBAtom::SetFormalCharge method. This occurs due to inadequate validation of input data structures, leading the parser to attempt modification of a non-existent atom. The primary impact is a crash of the affected service, affecting availability.

Proof of Concept (PoC):

An attacker submits a malformed MOL2 file to an Open Babel endpoint. The parsing engine reads an invalid atom index, causing OBAtom::SetFormalCharge to receive a NULL pointer. The function proceeds to operate on the address, triggering a segment violation. The outcome is a service-wide crash, preventing legitimate chemistry data analysis.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-2705>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-2705>

CVE-2026-48808

Finding: Twig Sandbox Property Allowlist Bypass

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 54/100 | CWE: CWE-693

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

Twig exhibits a sandbox property allowlist bypass via the 'column' filter under SourcePolicyInterface. The vulnerability exists because the policy validation logic fails to enforce restriction on dynamic property keys provided by the user. An attacker can leverage this to access restricted object properties that should be hidden by the sandbox.

Proof of Concept (PoC):

An attacker crafts a malicious template containing the 'column' filter with sensitive property names. The Twig engine fails to validate the key against the sandbox policy definition. Consequently, the filter allows the template to access properties that are prohibited by SourcePolicyInterface. The impact is the leakage of sensitive internal object states or data structures.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48808>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48808>

CVE-2026-48807

Finding: Twig Sandbox __toString Policy Bypass

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 54/100 | CWE: CWE-693

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

Twig contains a sandbox __toString() policy bypass via Traversable objects in 'join' and 'replace' filters. The failure stems from inconsistent handling of object-to-string casting when the object implements the Traversable interface. An attacker can exploit this to perform unauthorized actions or read forbidden data via triggered string conversions.

Proof of Concept (PoC):

An attacker creates a Twig template containing an object that implements the Traversable interface. The attacker passes this object into a 'join' or 'replace' filter designed to force a string conversion. Because of the missing policy check in these filters, the __toString() method is invoked outside of the allowed sandbox context. This allows the attacker to execute arbitrary logic defined within the object's string representation method.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48807>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48807>

CVE-2026-48806

Finding: Twig Sandbox Mapping Keys Bypass

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 54/100 | CWE: CWE-693

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

Twig allows a sandbox `__toString()` policy bypass via dynamic mapping keys. The vulnerability exists because the sandbox filter does not correctly validate mapping keys during template compilation or runtime rendering. This flaw allows an attacker to execute arbitrary logic during key lookup if the key involves a castable object.

Proof of Concept (PoC):

An attacker submits a template where an object is used as a key within a mapping structure. When the engine evaluates the mapping access, the object is implicitly converted to a string to perform the lookup. Since the sandbox check is absent, the `__toString()` method is executed as the key is resolved. The attacker gains the ability to trigger unauthorized code paths inside the sandbox.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48806>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48806>

CVE-2026-50565

Finding: ServiceAccount Token Exposure in Fission Builder

CVSS v3.1 Score: 5.9 | Severity: Medium | Urgency Score: 54/100 | CWE: CWE-250

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:L/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Fission builder pods are configured to auto-mount the fission-builder ServiceAccount token in user-supplied builder containers. This design flaw grants users unauthorized access to the builder's highly privileged service-account credentials. An attacker can exfiltrate this token to gain expanded access within the Kubernetes namespace.

Proof of Concept (PoC):

A user initiates a build job through Fission. The builder container mounts the Kubernetes service-account token at the

default path `/var/run/secrets/kubernetes.io/serviceaccount/`. The user submits malicious code that executes within the builder environment to read the token file. The exfiltrated token allows the user to interact with the Kubernetes API using the builder's permissions.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50565>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50565>

CVE-2026-49835

Finding: OOM in Sigstore Timestamp Authority

CVSS v3.1 Score: 5.9 | Severity: Medium | Urgency Score: 53/100 | CWE: CWE-770

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network	Attack Complexity	High
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	None	Availability Impact	High

Description:

The Sigstore Timestamp Authority suffers from an Out-of-Memory (OOM) condition due to unbounded metric label cardinality. The failure is caused by an accumulation of high-cardinality data inputs that are processed into monitoring metrics without a limit. This allows an attacker to exhaust system memory and cause a denial of service.

Proof of Concept (PoC):

The attacker sends a high volume of requests with unique, dynamically generated parameters that end up as metric labels in the Sigstore logs. The monitoring middleware fails to aggregate these labels, creating an unbounded set of metric entries in memory. As the memory consumption grows, the system process crashes due to an OOM error. This results in a persistent denial-of-service for the timestamping service.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49835>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49835>

CVE-2026-2704

Finding: Out-of-Bounds Read in CIF Transform

CVSS v3.1 Score: 5.4 | Severity: Medium | Urgency Score: 50/100 | CWE: CWE-119

MITRE ATT&CK: T1592

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:L

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	Required
Scope	Unchanged	Confidentiality Impact	Low
Integrity Impact	None	Availability Impact	Low

Description:

Open Babel has an out-of-bounds read vulnerability in the CIF transform3d::DescribeAsString method. This is caused by an off-by-one error when processing string conversions for coordinate transformations. An attacker can use this to leak

sensitive memory contents or crash the process.

Proof of Concept (PoC):

A user provides a maliciously crafted CIF file format to the application. The system calls `transform3d::DescribeAsString` to log or display the coordinate data. Because of the faulty bounds logic, the function reads past the end of the input buffer during conversion. This results in the potential disclosure of small chunks of heap data to the user interface.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-2704>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-2704>

CVE-2026-48796

Finding: Path Traversal in CefSharp FolderSchemeHandler

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 48/100 | CWE: CWE-22

MITRE ATT&CK: T1005

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

CefSharp.Common's `FolderSchemeHandlerFactory` has a path boundary check vulnerability that can expose files outside the configured root folder. The flaw arises from insufficient sanitization of path parameters before resolving the filesystem path. An attacker can exploit this to access and disclose sensitive configuration or system files.

Proof of Concept (PoC):

The attacker sends a web request to the CefSharp host using path manipulation sequences like `'../'` in the resource URL. The `FolderSchemeHandlerFactory` fails to properly validate the resulting path against the defined base directory. Consequently, the application opens and returns the contents of files outside the restricted folder. The attacker successfully reads sensitive system-wide files.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48796>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48796>

CVE-2026-55219

Finding: Credit Double-Spend Race Condition in Paymenter

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 43/100 | CWE: CWE-362

MITRE ATT&CK: T1496

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:N/I:H/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

Paymenter contains a race condition in the `payWithCredit()` method that enables credit double-spend attacks. The root cause is a lack of atomic locking mechanisms when updating user balance fields during parallel transaction requests. This allows an attacker to manipulate financial records, resulting in potential monetary loss.

Proof of Concept (PoC):

An authenticated user initiates two concurrent POST requests to the payment endpoint calling `payWithCredit()`. The server processes both requests simultaneously before the first transaction has updated the database balance. Due to the lack of a row-level lock, the system deducts the balance twice despite insufficient funds. This grants the user unauthorized credit availability in the application.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55219>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55219>

CVE-2026-49820

Finding: Open Redirect via Path Normalization

CVSS v3.1 Score: 6.1 | Severity: Medium | Urgency Score: 37/100 | CWE: CWE-601

MITRE ATT&CK: T1204

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

Probo exhibits an open redirect vulnerability caused by improper path normalization logic. The failure allows an attacker to bypass domain-based filters by using encoded path characters or URL segments. This facilitates phishing attacks where users are redirected to arbitrary malicious domains.

Proof of Concept (PoC):

An attacker creates a link that points to a Probo login page with a redirect parameter containing a double-encoded path. Probo's normalization function decodes the path and sees a valid relative URL, then fails to enforce domain origin checks. The victim is then redirected to an external attacker-controlled domain after the initial validation. This leads to credential harvesting via deceptive site presentation.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49820>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49820>

CVE-2026-48805

Finding: Twig Sandbox State Regression

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 30/100 | CWE: CWE-693

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Network
Privileges Required	None

Attack Complexity	Low
User Interaction	None

Scope	Unchanged
Integrity Impact	None

Confidentiality Impact	Low
Availability Impact	None

Description:

Twig has a sandbox state regression in deprecated internal wrappers within src/Resources/core.php. The issue occurs because restored legacy code lacks the modern security wrappers required to maintain the sandbox isolation boundary. An attacker can exploit these regressions to bypass intended sandboxing and perform unintended actions.

Proof of Concept (PoC):

An attacker targets specific deprecated features provided in the core.php library. By calling these legacy methods from a Twig template, the application avoids the standard sandbox policy checks. The legacy code executes without proper context restriction. This results in the leakage of minor internal configuration details.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48805>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48805>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from the GitHub Advisory Database and cross-references active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. All CVE identifiers, CVSS scores, and CWE mappings are sourced directly from official databases and are verifiable via the references provided in Section 5. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- GitHub Advisory Database -- <https://github.com/advisories>
- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>